2.Diseño de la estrategia de protección y monitorización

En este apartado explico mi estrategia de protección y monitorización, los pasos que voy a seguir resumidamente, cómo priorizaré las amenazas, como adaptaré las detecciones a las necesidades y recursos de Oryzon Biotech.

2.1. Fases del proyecto

Este es el orden de los pasos que voy a seguir en este proyecto:

1. Desplegar y configurar Splunk SIEM e instalar los agentes de monitorización en los equipos Windows.
2. Implementar reglas de detección comunitarias de Splunk basadas en MITRE ATT&CK (catálogo de técnicas utilizadas por los atacantes.)
3. Automatizar el envío de alertas por correo electrónico cuando se detecten amenazas, asignándoles un nivel de criticidad según el evento.
4. Desarrollar correlaciones (Relacionar varias detecciones de amenazas para identificar posibles ataques.)
5. Crear un Dashboard empresarial personalizado para centralizar y visualizar la actividad registrada en los equipos Windows monitorizados.
6. Mejorar continuamente las detecciones, ajustar las alertas y reducir los falsos positivos.

2.2. Enfoque de trabajo y toma de decisiones

Estos son los criterios y decisiones que seguiré durante el proyecto, adaptándolos a las necesidades de Oryzon Biotech, a la forma de trabajo que quiero implementar y a los recursos disponibles.

- **Enfoque de detección de amenazas:** me centraré en detectar principalmente accesos no autorizados, robos de credenciales, ransomware y posibles exfiltraciones de información.
- **Selección:** priorizaré las reglas de detección según los principales riesgos de Oryzon Biotech y las técnicas relevantes de MITRE ATT&CK.
- **Comportamiento de los usuarios:** tendré en cuenta riesgos como la reutilización de contraseñas, una gestión inadecuada de los permisos y los malos hábitos de ciberseguridad en la empresa.
- **Telemetría:** utilizaré únicamente estos registros de eventos Windows: Sysmon, Security y PowerShell Logging, evitando añadir eventos innecesarios que sobrecarguen el servidor Splunk.
- **Prioridad:** seleccionaré reglas de alta gravedad que requieran una respuesta inmediata.

- **Recursos limitados:** debido a los recursos limitados del servidor Linux que alojará Splunk, optimizaré su carga y evitaré procesar eventos y detecciones innecesarias que consuman recursos sin aportar valor.
- **Programación:** escalonaré los intervalos de ejecución de las búsquedas programadas para equilibrar la rapidez de detección y la carga del servidor.
- **Validación:** comprobaré que las reglas detectan correctamente las amenazas mediante pruebas controladas en el laboratorio.
- **Falsos positivos:** ajustaré las reglas para reducir alertas incorrectas y evitar notificaciones innecesarias.
- **Correlación:** combinaré detecciones relacionadas para identificar patrones de ataque que podrían pasar desapercibidos individualmente.
- **Mantenimiento:** revisaré periódicamente el funcionamiento de las reglas para corregir errores y mantener su eficacia.
- **Ampliación:** incorporaré detecciones adicionales de alto valor solo si los recursos disponibles lo permiten, como última prioridad.
- **Documentación:** Documentaré todo el progreso que haga durante el proyecto.